

Each region's cost may differ with respect to the services, and not all regions provide all the services. Also, while selecting the region, compliance regulations need to be considered.

Virtual private cloud (VPC)

In a public cloud space we can create a private isolated network known as virtual private cloud or VPC. This is just like the private cloud having both public and private subnets. The private cloud does not expose the IP addresses as public addresses and is accessible only through restricted means. VPC is essentially at the network layer as an IaaS service.

As an analogy, in IT parks different organisations can use different facilities such as parks and auditoriums, but the work area is private where only employees or restricted persons can enter. The VPC is similar to this private area. Users have proper control over it and it's also considered to be secure. For example, the web servers can be accessed from anywhere but the database can be accessed only by the backend application servers.

Multiple subnets can be created in the single VPC, within the range of the IP addresses the VPC is created with. The subnet can be either private or public, drawing the line for the servers in these networks not to access data from the public network.

VPC gateway endpoints allow connecting multiple VPCs, keeping the data private without using the internet.

Virtual LANs (VLANs) partition the network, and the connected group of servers can access each other without using the internet. Here, the partitioning occurs in layer two of the OSI model.

Virtual private networks (VPN) use encryption on top of the public network, making it secure and avoiding man-in-the-middle attacks.

Firewalls

Security groups act as a 'firewall' on instances. Using a security group, we can control both the incoming and outgoing traffic. They are stateful, which means any traffic that is allowed to go out, can go back in. They support only allow rules, which means traffic cannot be explicitly blocked, and only configured traffic is allowed in.

NACLs (network access control lists) act as a 'firewall' at the subnet level. We can associate a single NACL to multiple subnets, but only one NACL can be assigned a subnet.

Stateless inbound and outbound rules apply for all traffic. For example, if the output traffic is allowed our request will reach out, but if we expect a response, the outbound rules must be specified. Both allow and deny rules for both inbound and outbound traffic are supported. Here we can specify only a reference to a CIDR range (no hostname).

Cloud service providers also offer security at different OSI layers, such as WAF or web application firewall secured at layer 7, network firewall protected at layer 4, and so on. This enhances security by blocking unusual API calls, not allowing or allowing access from certain geographic locations, and tracking and reporting attempts made to access critical data.

IAM (identity and access management) policies

Cloud access to resources is governed by policies and their permissions centrally, with audit enabled by default. Each policy can be attached to the entity, user, user group or a role.

There are two basic policies -- identity based policy and resource based policy. Under identity based policy, permissions are given to the user or user group. The resource based policy defines who can access the data and what activities they are allowed to perform.

Access is granted only when both the policies allow it; if either policy denies access, it will not be granted. By default, all the access is denied, and only an explicit 'allow' grants the access. But if there is an explicit 'deny', it will get higher precedence and access will be denied.

Granular access policies can be set such as to allow or disallow certain IP addresses, data and time, group, geographic locations, etc.

Managing secrets

Applications that use API keys, encryption keys or credentials should not be hard coded. Cloud provides services to handle secrets elegantly. Secrets are encrypted at rest and in transit.

Secrets management protects and manages access to applications and services. IAM policies make sure one has access to secrets.

Central logging

Monitoring and auditing is a crucial phase of cyber security. The cloud provides a framework and services to manage and enable monitoring at the granular level.

IAM access, policy change, and infrastructure changes are some of the common tasks where the logging is default enabled and aggregated in the central location. But these are not sufficient; the cloud provides APIs to write customised logs based on the user's requirement.

These centralised logs can be used for further inspection and analysis, as well as integrated with any SEIM (security information and event management) solution. Intuitive reports can be created from these logs.

Cloud access security broker (CASB)

Each cloud service provider offers a set of tools that enable the security tools. But there could be gaps or these